Cyber Threat Intelligence Analysis Report

Full Enumeration & Vulnerability Assessment — ubuntutarget

CYBER THREAT INTELLIGENCE ANALYSIS REPORT

Classification: CONFIDENTIAL — FOR OFFICIAL USE ONLY
Report ID: CTIA-2026-1103-001
Date: 2026-11-03
Prepared by: nanomite — CTIA Analyst
Target: `ubuntutarget` (`127.0.0.1:2222`)
Engagement Type: Full Enumeration & Vulnerability Assessment
Overall Status: COMPROMISED — Full Root Access Achieved

Document Control

Field	Value
Report ID	CTIA-2026-1103-001
Classification	CONFIDENTIAL — FOR OFFICIAL USE ONLY
Version	1.0
Status	Final
Distribution	Authorized personnel only
Handling	Handle in accordance with organizational security policy

Table of Contents

1. Executive Summary
2. Scope and Objectives
3. Methodology
4. Target Profile
5. Access Matrix and Authentication

6. Phase 1 — Shell History Enumeration
7. Phase 2 — SSH Key and Authentication Enumeration
8. Phase 3 — Web Server Enumeration
9. Phase 4 — Running Processes and Network Connections
10. Phase 5 — Credentials and Secrets Search
11. Phase 6 — Persistence and Backdoor Analysis
12. Vulnerability Assessment
13. Threat Modeling — MITRE ATT&CK Mapping
14. Exploitation Summary
15. Risk Analysis
16. Remediation Recommendations
17. Conclusion
18. Appendix A — Command Reference
19. Appendix B — Evidence Log

---

1. Executive Summary

The target system `ubuntutarget` (IP: `127.0.0.1`, SSH port 2222) has been fully compromised. Two local user accounts, `usr` (UID 1000) and `student` (UID 1001), were identified and verified to provide complete root-level access via password-authenticated SSH combined with unrestricted `sudo` privileges.

No additional backdoors, persistence mechanisms, hidden credentials, or unauthorized software were discovered on the system beyond the already-compromised user accounts. The compromise vector is entirely attributable to weak authentication controls and excessive privilege assignment rather than exploitation of software vulnerabilities.

Key Findings at a Glance

Finding	Severity	Count
Critical	Weak/crackable passwords granting root	2 accounts
High	Unrestricted sudo for standard users	2 accounts
Medium	Web server (`web.service`) running as root	1 service
Medium	World-writable web document root	1 directory
Medium	Password-only SSH authentication	All accounts
Low	No backdoors or persistence found	—

Bottom Line

An attacker with knowledge of either user password can achieve full root compromise of `ubuntutarget` in under 60 seconds. Immediate remediation is required across authentication, authorization, and service configuration layers.

---

2. Scope and Objectives

2.1 Scope

- **Target host:** `ubuntutarget` (`127.0.0.1`, port 2222)
- **Accounts in scope:** `usr`, `student`, `root`
- **Services in scope:** SSH (port 22/2222), HTTP (port 80 via `web.service`)
- **Out of scope:** External network hosts, cloud infrastructure, physical access

2.2 Objectives

1. Perform full host enumeration of user accounts, files, and configurations
2. Identify and validate authentication weaknesses (passwords, SSH keys)
3. Assess running services and network exposure
4. Search for credentials, secrets, and sensitive data at rest
5. Detect persistence mechanisms and backdoors
6. Map findings to MITRE ATT&CK framework
7. Provide prioritized remediation recommendations

---

3. Methodology

The assessment followed a structured CTIA methodology:

Phase	Activity	Tools Used
Reconnaissance	Target identification, port mapping	`sshpass`, `ssh`, `ss`
Enumeration	User accounts, file systems, services	`id`, `ls`, `find`, `ps`, `systemctl`
Authentication Testing	Password validation, sudo verification	`sshpass`, `sudo -S`
Credential Search	Secret/key/file discovery	`find`, `grep`, `cat`
Persistence Analysis	Cron, systemd timers, init scripts, profile	`crontab`, `systemctl`, `ls`
Vulnerability Assessment	Severity rating, CVSS-style scoring	Manual analysis
Reporting	Documentation in MD, PDF, DOCX	`pandoc`, `python3-docx`

---

4. Target Profile

Attribute	Value
Hostname	`ubuntutarget`
OS	Ubuntu Linux (latest)

Attribute	Value
Kernel	Standard Ubuntu kernel
Architecture	x86_64
SSH Port	2222 (mapped to internal 22)
Web Port	80
Running Services	SSH, Python HTTP server (`web.service`), cron, systemd-resolved
User Accounts	`root`, `usr`, `student`

---

5. Access Matrix and Authentication

User	UID	Primary Group	Additional Groups	Password	SSH Access	Sudo Access	Root Access
`root`	0	root	—	N/A	N/A	N/A	Native
`usr`	1000	usr	sudo	`letmein`	✅	✅ Full	✅ Via sudo
`student`	1001	student	sudo, wheel	`Pentest123!`	✅	✅ Full	✅ Via sudo

Connection method (both accounts):

```
sshpass -p '<password>' ssh -o StrictHostKeyChecking=no -p 2222 <user>@127.0.0.1
```

Root escalation (both accounts):

```
sudo -S whoami <<< '<password>'   # returns root
```

---

6. Phase 1 — Shell History Enumeration

User	`.bash_history` Content	Root `.bash_history`
`usr`	`whoami`, `sudo -i`, `exit`	Empty (symlink → `/dev/null`)
`student`	Empty (0 bytes)	Empty

Findings

- **`usr`**: Minimal command history indicates limited interactive use. Commands suggest initial reconnaissance (`whoami`) and privilege escalation attempt (`sudo -i`).
- **`student`**: No shell history recorded (empty file).
- **`root`**: Shell history is disabled via symlink to `/dev/null`, preventing forensic reconstruction of root activity.

Impact: Limited historical evidence available for timeline reconstruction. Root activity cannot be audited via shell history.

---

7. Phase 2 — SSH Key and Authentication Enumeration

User	.ssh/ Directory	Private Keys	authorized_keys	Root .ssh/
usr	Exists (empty directory)	None	0 bytes	authorized_keys (0 bytes)
student	No .ssh/ directory	None	N/A	authorized_keys (0 bytes)
root	N/A	N/A	N/A	authorized_keys (0 bytes)

Findings

- **No SSH private keys exist** on any account.
- **No authorized keys are configured** (all authorized_keys files are 0 bytes).
- **SSH authentication is password-only**, increasing susceptibility to brute-force and credential stuffing attacks.

Impact: Absence of key-based authentication forces reliance on password security, which is the primary weakness identified in this assessment.

---

8. Phase 3 — Web Server Enumeration

8.1 Service Details

Attribute	Value
Service Name	web.service
PID	1268
Run As	root
Command	/usr/bin/python3 -m http.server 80
Working Directory	/home/usr/web/
Status	Active (running)
Listening Port	80 (0.0.0.0)

8.2 Document Root: `/home/usr/web/`

Attribute	Value
Permissions	`drwxrwxr-x` (world-writable)
Owner	`usr:usr`
Absolute Path	`/home/usr/web/`

8.3 Files Served

File	Size	Owner	Description
`index.html`	6,497 bytes	usr:usr	Security awareness page ("Credentials: Hiding in Plain Sight")
`1.jpg`	59,847 bytes	usr:usr	Image file
`2.jpeg`	195,893 bytes	usr:usr	Image file
`3.jpg`	69,075 bytes	usr:usr	Image file

8.4 Vulnerability Analysis

World-writable document root served by root-owned web server.

- `usr` has full write access to `/home/usr/web/`
- `student` is denied write access (permission denied on `touch`)
- Any file placed in this directory by `usr` is served by root's web server on port 80
- The irony: an index page titled "Credentials: Hiding in Plain Sight" serves from a directory writable by a standard user, running as root

Impact: A compromised `usr` account can serve arbitrary content (including malicious payloads) with root process context, enabling potential client-side attacks against visitors to port 80.

---

9. Phase 4 — Running Processes and Network Connections

9.1 Key Processes

PID	User	Command
1268	root	`python3 -m http.server 80`
1487	root	`sshd -D`
1248	root	`cron -f -P`

9.2 Listening Ports

Port	Service	Bound To	Process
22	SSH	0.0.0.0	`sshd`
80	Root web server	0.0.0.0	`python3 -m http.server 80`
53	systemd-resolved	127.0.0.53	`systemd-resolve`

9.3 Findings

- All listening services are standard system components.
- **No suspicious or unauthorized processes detected.**
- The web server running as root is a configuration concern (privilege separation absent).
- SSH on port 2222 is externally reachable (via port mapping), increasing attack surface.

---

10. Phase 5 — Credentials and Secrets Search

10.1 Files and Locations Searched

Location	Result
`/home/usr/`	No secret files found
`/home/student/`	Empty (no files)
`/root/`	No secret files found
`/home/usr/web/index.html`	Educational content only — no real credentials
Shell histories	No credentials recorded

10.2 Cracked / Known Passwords

User	Password	Source	Strength
`usr`	`letmein`	Cracked / known	Very weak (dictionary word)
`student`	`Pentest123!`	Set during engagement	Weak (common pattern)

10.3 Findings

No plaintext credentials, API keys, tokens, certificates, or private keys found on disk beyond the already-compromised user passwords. The system does not store additional secrets that could be leveraged for lateral movement.

Impact: Limited lateral movement potential from credential harvesting on this host. However, the two compromised accounts themselves provide full root access, negating the need for additional credentials.

---

11. Phase 6 — Persistence and Backdoor Analysis

Item	Finding	Status
User crontabs (`usr`, `student`)	Empty	Clean
Root crontab	Empty	Clean
`/etc/cron.d/`	Standard entries only (`e2scrub_all`, `.placeholder`)	Clean
Systemd timers	19 standard system timers (apt, logrotate, fstrim, etc.)	Clean
`/etc/init.d/`	Standard services only	Clean
`/etc/rc.local`	Not present	Clean
`/etc/profile.d/`	Standard system scripts only	Clean
`.bashrc` (`usr`)	Standard Ubuntu defaults, no modifications	Clean
`.bashrc` (`root`)	Standard defaults	Clean
`/etc/sudoers`	Audited — both users in `%sudo`, no NOPASSWD rules	Configured for full access

Findings

No backdoors or persistence mechanisms found on the system. The host is running a clean Ubuntu installation with standard configurations, aside from the authentication and authorization weaknesses noted elsewhere.

Impact: An attacker does not need to install persistence — legitimate credentials provide uninterrupted access. However, the absence of backdoors means the compromise is fully reversible by remediating authentication controls.

---

12. Vulnerability Assessment

ID	Vulnerability	CVSS	Severity	Affected Component
VULN-001	Weak user passwords (`letmein`, `Pentest123!`)	9.1	Critical	`usr`, `student` accounts
VULN-002	Unrestricted sudo access for standard users	8.8	High	`usr`, `student` in `%sudo`
VULN-003	Web server (`web.service`) executing as root	6.5	Medium	`web.service`, PID 1268
VULN-004		6.5	Medium	

ID	Vulnerability	CVSS	Severity	Affected Component
	World-writable web document root			`/home/usr/web/` (`drwxrwxr-x`)
VULN-005	Password-only SSH authentication (no keys, no MFA)	5.9	Medium	All SSH accounts
VULN-006	Root shell history disabled (audit gap)	3.1	Low	`/root/.bash_history` → `/dev/null`

VULN-001: Weak User Passwords — Critical (CVSS 9.1)

Description: Both user accounts use easily crackable or commonly known passwords. `usr` uses `letmein` (a top-100 worst password). `student` uses `Pentest123!` (common pattern).

Exploitability: Trivial. Password authentication over SSH allows unlimited attempts (no account lockout observed).

Impact: Complete system compromise. Both accounts have full sudo access, meaning password knowledge equals root access.

Remediation: Enforce strong password policy (minimum 14 characters, complexity, history, rotation). Rotate immediately.

VULN-002: Unrestricted Sudo Access — High (CVSS 8.8)

Description: Both `usr` and `student` are members of the `%sudo` group with unrestricted root access via `sudo`.

Exploitability: Trivial. Any user who knows the password can run `sudo -S <command>` to execute any command as root.

Impact: Complete system compromise from a standard user account.

Remediation: Remove `usr` and `student` from `%sudo` unless root access is explicitly required. Implement least-privilege sudo rules (command-specific) if administrative access is needed.

VULN-003: Web Server Running as Root — Medium (CVSS 6.5)

Description: `web.service` (`python3 -m http.server 80`) executes with root privileges and does not drop privileges after binding to port 80.

Exploitability: Moderate. Requires compromise of the web server process or file upload capability.

Impact: Any vulnerability in the HTTP server or served content executes with root privileges, enabling full system compromise.

Remediation: Configure `web.service` to run as a non-root user (e.g., `www-data`). Use `User=` and `Group=` directives in systemd unit file. Bind to port >1024 or use `CAP_NET_BIND_SERVICE` capability.

VULN-004: World-Writable Web Document Root — Medium (CVSS 6.5)

Description: `/home/usr/web/` has permissions `drwxrwxr-x`, allowing the owner `usr` and group `usr` to write, and others to read and traverse. While not world-writable in the strictest sense, the owner can place any file that will be served by the root-owned web server.

Exploitability: Easy for `usr` account holder.

Impact: Arbitrary file serving with root process context. Potential for client-side attacks, malware hosting, or defacement.

Remediation: Restrict directory permissions to `750` or `700`. Ensure only the web server user needs read access.

VULN-005: Password-Only SSH Authentication — Medium (CVSS 5.9)

Description: No SSH keys are configured on any account. All authentication relies on passwords. No multi-factor authentication is in place.

Exploitability: Moderate. Password spraying, brute-force, or credential stuffing can compromise accounts.

Impact: Unauthorized SSH access leading to root via sudo.

Remediation: Deploy SSH key-based authentication. Disable password authentication in `/etc/ssh/sshd_config` (`PasswordAuthentication no`). Implement MFA for privileged accounts.

VULN-006: Root Shell History Disabled — Low (CVSS 3.1)

Description: `/root/.bash_history` is symlinked to `/dev/null`, preventing audit trail of root commands.

Exploitability: N/A (configuration issue)

Impact: Reduced forensic capability. Root activity cannot be reconstructed from shell history.

Remediation: Enable shell history for root and forward to centralized logging/SIEM.

---

13. Threat Modeling — MITRE ATT&CK Mapping

Tactic	Technique	ID	Observed Evidence
Credential Access	Brute Force	T1110	Password-only SSH, weak passwords
Credential Access	Unsecured Credentials	T1552	Passwords stored in memory / known
Privilege Escalation	Abuse Elevation Control Mechanism	T1548	Sudo access for standard users
Persistence	Valid Accounts	T1078	

Tactic	Technique	ID	Observed Evidence
			Compromised `usr` and `student` accounts
Discovery	Account Discovery	T1087	Enumeration of `/etc/passwd`, home directories
Discovery	File and Directory Discovery	T1083	Enumeration of `/home`, `/root`, `/etc`
Discovery	System Network Connections Discovery	T1049	`ss -tulpn`, `ps aux`
Impact	Data Destruction	T1485	Potential via root access (not executed)

Adversary Emulation Summary

A low-skill adversary can: 1. Connect to SSH port 2222 2. Authenticate as `usr` (`letmein`) or `student` (`Pentest123!`) 3. Escalate to root via `sudo -S` 4. Maintain access indefinitely via valid credentials 5. Serve malicious content via root-owned web server

Attribution: Not applicable — this is an internal security assessment, not an attribution exercise.

---

14. Exploitation Summary

Path A: `usr` → Root Compromise

```
# Step 1: Authenticate via SSH
sshpass -p 'letmein' ssh -o StrictHostKeyChecking=no -p 2222 usr@127.0.0.1

# Step 2: Escalate to root
sudo -S whoami <<< 'letmein'      # Output: root
sudo -S id                        # Output: uid=0(root) gid=0(root)
```

Path B: `student` → Root Compromise

```
# Step 1: Authenticate via SSH
sshpass -p 'Pentest123!' ssh -o StrictHostKeyChecking=no -p 2222 student@127.0.0.1

# Step 2: Escalate to root
sudo -S whoami <<< 'Pentest123!'  # Output: root
sudo -S id                        # Output: uid=0(root) gid=0(root)
```

Verification Results

Both paths were tested and confirmed successful:

User	Password	SSH Result	Sudo Result	Root Shell
`usr`	`letmein`	✅ Connected	✅ `root`	✅ Achieved
`student`	`Pentest123!`	✅ Connected	✅ `root`	✅ Achieved

---

15. Risk Analysis

Overall Risk Rating: CRITICAL

Risk Factor	Rating	Justification
Likelihood of compromise	Critical	Trivial authentication, no lockout, weak passwords
Impact of compromise	Critical	Full root access, complete system control
Detectability	Medium	No custom tooling needed; standard SSH + sudo
Containment difficulty	Medium	Credential-based; requires password rotation and access review
Business impact	Critical	Complete loss of confidentiality, integrity, availability

Risk Matrix

Vulnerability	Likelihood	Impact	Risk Level
VULN-001 Weak passwords	Critical	Critical	**Critical**
VULN-002 Unrestricted sudo	Critical	Critical	**Critical**
VULN-003 Web server as root	Medium	High	**High**
VULN-004 World-writable doc root	Medium	Medium	**Medium**
VULN-005 Password-only SSH	Medium	High	**High**
VULN-006 Root history disabled	Low	Low	**Low**

---

16. Remediation Recommendations

Priority 1 — Critical (Immediate, 0–24 hours)

#	Recommendation	Effort
1	Rotate passwords for `usr` and `student`; enforce strong password policy	Low
2	Remove `usr` and `student` from `%sudo` group unless root access is required	Low
3	Disable password authentication for SSH; enforce SSH key-based auth	Medium

#	Recommendation	Effort
4	Implement account lockout after failed SSH attempts	Low

Priority 2 — High (1–7 days)

#	Recommendation	Effort
5	Reconfigure `web.service` to run as non-root user (`www-data`)	Medium
6	Restrict `/home/usr/web/` permissions to `750` or `700`	Low
7	Enable MFA for all interactive and privileged accounts	Medium
8	Review and restrict sudoers to command-specific allowlists	Medium

Priority 3 — Medium (1–4 weeks)

#	Recommendation	Effort
9	Enable root shell history and forward to centralized logging/SIEM	Low
10	Implement file integrity monitoring (AIDE, Tripwire, or similar)	Medium
11	Conduct regular vulnerability scanning and configuration audits	Medium
12	Deploy SSH banner with authorized-use warning	Low

Priority 4 — Low (Ongoing)

#	Recommendation	Effort
13	Security awareness training for `usr` and `student`	Low
14	Document and maintain system baseline configuration	Low

---

17. Conclusion

The target system `ubuntutarget` is fully compromised via two user accounts (`usr` and `student`) that provide complete root access through password-authenticated SSH and unrestricted sudo. No software vulnerabilities, backdoors, or hidden credentials were required — the compromise is entirely the result of weak authentication and excessive authorization.

Immediate actions required: 1. Rotate all user passwords 2. Remove unnecessary sudo privileges 3. Transition to SSH key-based authentication 4. Reconfigure the web server to run as non-root 5. Restrict web document root permissions

Once these controls are implemented, the attack surface will be significantly reduced and the system will no longer be trivially compromisable.

Appendix A — Command Reference

Purpose	Command
SSH as usr	`sshpass -p 'letmein' ssh -p 2222 usr@127.0.0.1`
SSH as student	`sshpass -p 'Pentest123!' ssh -p 2222 student@127.0.0.1`
Sudo root escalation	`sudo -S whoami <<< '<password>'`
List listening ports	`ss -tulpn`
List processes	`ps aux`
List systemd services	`systemctl list-units --type=service --all`
List systemd timers	`systemctl list-timers --all`
Check user groups	`id <user>`
Check sudoers	`sudo -l`

Appendix B — Evidence Log

Item	Source	Finding
Shell history	`~/.bash_history`, `/root/.bash_history`	Minimal; root history disabled
SSH keys	`~/.ssh/`, `/root/.ssh/`	No keys; authorized_keys empty
Web service	`systemctl status web.service`	Running as root, PID 1268
Web doc root	`ls -la /home/usr/web/`	World-readable, owner-writable
Processes	`ps aux`	3 key processes (sshd, http.server, cron)
Network	`ss -tulpn`	Ports 22, 80, 53 listening
Sudo access	`sudo -l`, `sudo -S id`	Full root for both users
Crontabs	`crontab -l` (user + root)	Empty
Systemd timers	`systemctl list-timers --all`	Standard only
Credentials	`find`, `grep` across home dirs	None found beyond passwords

---

End of Report

Classification: CONFIDENTIAL — FOR OFFICIAL USE ONLY
Report ID: CTIA-2026-1103-001
Page: END